

Report Analisi Threat Intelligence & IOC

Oggetto: Analisi del file di cattura Cattura_U3_W1_L3.pcapng

Analista: Kevin Motti

Data: 06/02/2026

1. Executive Summary

L'analisi del traffico di rete fornito evidenzia una fase attiva di **Reconnaissance (Ricognizione)** condotta all'interno della rete locale. Un host attaccante ha eseguito una scansione automatizzata delle porte (Port Scanning) verso un target specifico, identificando numerosi servizi critici e obsoleti aperti. L'attività è preliminare a un potenziale attacco mirato allo sfruttamento di vulnerabilità note.

2. Identificazione degli Attori (Network Topology)

Dall'analisi dei pacchetti ARP e TCP, sono stati identificati i seguenti attori:

- **Attacker (Threat Actor):** 192.168.200.100
 - *Comportamento:* Invia richieste di connessione sequenziali ad alta velocità.
 - *MAC Address:* 08:00:27:39:7d:fe (PCSystemtec - VirtualBox/VMware environment).
- **Victim (Target):** 192.168.200.150
 - *Comportamento:* Risponde alle richieste e annuncia la propria presenza.
 - *Identità:* Identificata esplicitamente nel **Pacchetto 1** (protocollo BROWSER) come **"METASPLOITABLE"**, una macchina virtuale intenzionalmente vulnerabile.

1	0.000000000	192.168.200.150	192.168.200.255	BROWSER	286	Host Announcement METASPLOITABLE, workstation, Server, Print Queue Server, Xenix Server, NT Workstation, NT Server, Potential B
2	23.764214995	192.168.200.100	192.168.200.150	TCP	74	53060 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522427 TSecr=0 WS=128
3	23.764287788	192.168.200.100	192.168.200.150	TCP	74	33876 -> 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522429 TSecr=0 WS=128
4	23.764777323	192.168.200.150	192.168.200.100	TCP	74	80 -> 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951165 TSecr=810522427 WS=64
5	23.764777427	192.168.200.150	192.168.200.100	TCP	60	443 -> 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6	23.764813260	192.168.200.100	192.168.200.150	TCP	60	53060 -> 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7	23.764890991	192.168.200.100	192.168.200.150	TCP	60	53060 -> 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
8	28.761629461	PCSystemtec,fd:87:...	PCSystemtec,fd:7d:...	ARP	60	who has 192.168.200.100? Tell 192.168.200.150
9	28.761644619	PCSystemtec,fd:7d:...	PCSystemtec,fd:87:...	ARP	42	192.168.200.100 is at 08:00:27:39:7d:fe
10	28.774652257	PCSystemtec,fd:7d:...	PCSystemtec,fd:87:...	ARP	42	who has 192.168.200.150? Tell 192.168.200.100
11	28.775230099	PCSystemtec,fd:87:...	PCSystemtec,fd:7d:...	ARP	60	192.168.200.150 is at 08:00:27:fd:87:1e
12	36.774143445	192.168.200.100	192.168.200.150	TCP	74	41304 -> 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
13	36.774218116	192.168.200.100	192.168.200.150	TCP	74	50120 -> 111 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
14	36.774257841	192.168.200.100	192.168.200.150	TCP	74	33878 -> 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
15	36.774366305	192.168.200.100	192.168.200.150	TCP	74	50636 -> 554 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
16	36.774485627	192.168.200.100	192.168.200.150	TCP	74	52358 -> 135 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
17	36.774535534	192.168.200.100	192.168.200.150	TCP	74	46138 -> 993 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
18	36.774614776	192.168.200.100	192.168.200.150	TCP	74	41182 -> 21 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
19	36.774685505	192.168.200.150	192.168.200.100	TCP	74	23 -> 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
20	36.774685652	192.168.200.150	192.168.200.100	TCP	74	111 -> 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
21	36.774685696	192.168.200.150	192.168.200.100	TCP	60	443 -> 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
22	36.774685737	192.168.200.150	192.168.200.100	TCP	60	554 -> 50636 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
23	36.774685776	192.168.200.150	192.168.200.100	TCP	60	135 -> 52358 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
24	36.774700464	192.168.200.100	192.168.200.150	TCP	66	41304 -> 23 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
25	36.774711072	192.168.200.100	192.168.200.150	TCP	66	56120 -> 111 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
26	36.77511184	192.168.200.150	192.168.200.100	TCP	60	993 -> 46138 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
27	36.775141273	192.168.200.150	192.168.200.100	TCP	74	21 -> 41182 [SYN, ACK] Seq=1 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535438 WS=64
28	36.775174048	192.168.200.100	192.168.200.150	TCP	66	41182 -> 21 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535438 TSecr=4294952466
29	36.775337890	192.168.200.100	192.168.200.150	TCP	74	50174 -> 113 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535438 TSecr=0 WS=128
30	36.775384694	192.168.200.100	192.168.200.150	TCP	74	55656 -> 22 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
31	36.775524204	192.168.200.100	192.168.200.150	TCP	74	53062 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128
32	36.775589806	192.168.200.150	192.168.200.100	TCP	60	113 -> 50174 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
33	36.775619484	192.168.200.150	192.168.200.100	TCP	60	41304 -> 23 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
34	36.775652487	192.168.200.100	192.168.200.150	TCP	60	50120 -> 111 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
35	36.775796938	192.168.200.150	192.168.200.100	TCP	74	22 -> 55656 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=64
36	36.775797004	192.168.200.150	192.168.200.100	TCP	74	80 -> 53062 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
37	36.775803786	192.168.200.100	192.168.200.150	TCP	60	55656 -> 22 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
38	36.775813232	192.168.200.100	192.168.200.150	TCP	60	53062 -> 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
39	36.775861964	192.168.200.100	192.168.200.150	TCP	66	41182 -> 21 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
40	36.775915976	192.168.200.100	192.168.200.150	TCP	60	53066 -> 22 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
41	36.776062853	192.168.200.100	192.168.200.150	TCP	60	53062 -> 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810535439 TSecr=4294952466
42	36.776179338	192.168.200.100	192.168.200.150	TCP	74	50684 -> 199 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535439 TSecr=0 WS=128

3. Indicatori di Compromissione (IOC) e Analisi Tecnica

Sono stati isolati i seguenti indicatori che confermano l'attività ostile:

IOC 1: Traffico di Scansione Automatizzata (Port Scanning)

- **Evidenza:** Una raffica di pacchetti TCP con flag [SYN] inviati dall'IP .100 verso l'IP .150.
- **Timing:** L'intervallo tra i pacchetti è nell'ordine dei microsecondi (es. 36.782390 -> 36.782422), confermando l'uso di uno strumento automatico e non un'interazione umana.
- **Pattern ARP:** La presenza di richieste ARP "Who has 192.168.200.150?" conferma che l'attaccante si trova sulla stessa LAN fisica (Layer 2 adjacency).

```
1 0.000000000 192.168.200.150 192.168.200.255 BROWSER 286 Host Announcement METASPLOITABLE, Workstation, Server, Print Queue Server, Xenix Server, N
2 23.764214995 192.168.200.100 192.168.200.150 TCP 74 53060 -> 80 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSecr=0 WS=128
3 23.764287789 192.168.200.100 192.168.200.150 TCP 74 33876 -> 443 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810522428 TSecr=0 WS=128
4 23.764777323 192.168.200.150 192.168.200.100 TCP 74 80 -> 53060 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294951165 TSecr=
5 23.764777427 192.168.200.150 192.168.200.100 TCP 60 443 -> 33876 [RST, ACK] Seq=1 Ack=1 Win=0 Len=0
6 23.764815289 192.168.200.100 192.168.200.150 TCP 66 53060 -> 80 [ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
7 23.764899091 192.168.200.100 192.168.200.150 TCP 66 53060 -> 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
8 28.761629461 PCSSystemtec_fd:87: PCSSystemtec_39:7d: ARP 60 who has 192.168.200.100? Tell 192.168.200.150
9 28.761644619 PCSSystemtec_39:7d: PCSSystemtec_fd:87: ARP 42 192.168.200.100 is at 08:00:27:39:7d:fe
10 28.774852257 PCSSystemtec_39:7d: PCSSystemtec_fd:87: ARP 42 who has 192.168.200.150? Tell 192.168.200.100
11 28.775230999 PCSSystemtec_fd:87: PCSSystemtec_39:7d: ARP 60 192.168.200.150 is at 08:00:27:fd:87:1e
12 36.774143445 192.168.200.100 192.168.200.150 TCP 74 41304 -> 23 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM TSval=810535437 TSecr=0 WS=128
```

IOC 2: Handshake TCP Anomalo (Connect Scan)

- **Pattern Osservato:** L'attaccante completa il 3-Way Handshake (SYN -> SYN, ACK -> ACK) e invia immediatamente un RST (Reset) per chiudere la connessione.
- **Significato:** Questo comportamento indica che l'attaccante non è interessato a utilizzare il servizio, ma solo a verificarne l'esistenza e lo stato (Open/Closed).

```
7 23.764899091 192.168.200.100 192.168.200.150 TCP 66 53060 -> 80 [RST, ACK] Seq=1 Ack=1 Win=64256 Len=0 TSval=810522428 TSecr=4294951165
```

IOC 3: Esposizione di Servizi Critici (Vettori di Attacco)

L'analisi delle risposte [SYN, ACK] (filtro Wireshark: tcp.flags.syn==1 && tcp.flags.ack==1) ha rivelato le seguenti porte aperte, che rappresentano gravi vulnerabilità:

Porta (TCP)	Servizio	Rischio / Vettore di Attacco
21	FTP	Credenziali in chiaro, possibili backdoor (es. vsftpd 2.3.4).
23	Telnet	Protocollo non cifrato, sniffing di credenziali.
25	SMTP	Enumerazione utenti, Spam relay.

53	DNS	Zone Transfer (scaricamento mappa di rete) se mal configurato.
80	HTTP	Vulnerabilità web (SQLi, XSS, RFI).
139/445	SMB/NetBIOS	EternalBlue, Ransomware, Enumerazione utenti (enum4linux).
512/513/514	R-Services	rlogin, rexec, rsh. Accesso remoto insicuro (spesso senza password tramite .rhosts).

No.	Time	Source	Destination	Protocol	Length	Info
4	23.764777323	192.168.200.150	192.168.200.100	TCP	74	80 → 53960 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810522427 WS=64
19	36.774685505	192.168.200.150	192.168.200.100	TCP	74	23 → 41304 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
20	36.774685652	192.168.200.150	192.168.200.100	TCP	74	111 → 56120 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535437 WS=64
27	36.775141273	192.168.200.150	192.168.200.100	TCP	74	21 → 41102 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535438 WS=64
35	36.775796938	192.168.200.150	192.168.200.100	TCP	74	22 → 55656 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
36	36.775797004	192.168.200.150	192.168.200.100	TCP	74	80 → 53962 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535439 WS=64
57	36.776984828	192.168.200.150	192.168.200.100	TCP	74	445 → 33042 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
59	36.776984961	192.168.200.150	192.168.200.100	TCP	74	139 → 46990 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
61	36.776985043	192.168.200.150	192.168.200.100	TCP	74	25 → 60632 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
63	36.776985123	192.168.200.150	192.168.200.100	TCP	74	53 → 37282 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535440 WS=64
164	36.781487210	192.168.200.150	192.168.200.100	TCP	74	512 → 45648 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952466 TSecr=810535445 WS=64
267	36.788985940	192.168.200.150	192.168.200.100	TCP	74	514 → 51396 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952467 TSecr=810535452 WS=64
994	36.825722953	192.168.200.150	192.168.200.100	TCP	74	513 → 42040 [SYN, ACK] Seq=0 Ack=1 Win=5792 Len=0 MSS=1460 SACK_PERM TSval=4294952471 TSecr=810535489 WS=64

4. Deduzione della Metodologia di Attacco (Nmap)

Basandosi sulla firma del traffico, è possibile ricostruire con alta probabilità il comando utilizzato dall'attaccante.

Tool Utilizzato: Nmap (Network Mapper)

Comando Dedotto:

```
nmap -sV -p- 192.168.200.150
```

Analisi dei Flag:

1. **-sV (Version Detection):** Abbiamo osservato che l'attaccante completa la connessione TCP (invia l'ACK finale dopo il SYN-ACK). Il classico "Stealth Scan" (-sS) solitamente invia il RST *prima* di completare l'handshake. Il completamento suggerisce che Nmap stava cercando di leggere il banner del servizio (Version Detection).
2. **-p- (All Ports) o scansione ampia:** L'attaccante ha scansionato porte non standard e

porte "alte" (oltre la 1024), indicando una scansione completa o molto estesa, non limitata alle top 1000.

5. Ipotesi sui Potenziali Vettori di Attacco Futuri

Data la natura dei servizi scoperti ("Metasploitable"), lo scenario più probabile per l'attacco successivo include:

1. **Remote Code Execution (RCE):** Sfruttando la porta **445 (Samba)** o la porta **514 (RSH)** per ottenere una shell di comando.
2. **Brute Force / Credential Stuffing:** Attacco diretto ai servizi **Telnet (23)** e **SSH (22)**.
3. **Exploit Web:** Attacco al server web sulla porta **80** (es. PHP injection).

6. Azioni di Mitigazione Consigliate (Remediation)

Per ridurre l'impatto dell'attacco attuale e prevenire compromissioni future, si consigliano le seguenti azioni immediate:

1. **Isolamento Immediato:** Disconnettere la macchina 192.168.200.150 dalla rete per prevenire movimenti laterali (specialmente via SMB porta 445).
2. **Chiusura Servizi "Legacy":** Disabilitare immediatamente i servizi non necessari e insicuri:
 - **Telnet (23):** Sostituire obbligatoriamente con SSH.
 - **R-Services (512, 513, 514):** Rimuovere completamente; sono protocolli obsoleti e intrinsecamente insicuri.
 - **FTP (21):** Sostituire con SFTP.
3. **Firewalling:** Implementare regole di firewall (iptables o appliance esterna) per bloccare tutto il traffico in ingresso tranne quello strettamente necessario (principio del *Least Privilege*).
4. **Patching:** Aggiornare il servizio Samba (porte 139/445) per mitigare vulnerabilità note come EternalBlue.
5. **Disabilitazione Zone Transfer:** Configurare il server DNS (porta 53) per rifiutare richieste di trasferimento zona da IP non autorizzati.

Conclusione:

L'analisi conferma che il target è un sistema *honey-pot* o un laboratorio di test estremamente vulnerabile. In un ambiente di produzione, questa configurazione rappresenterebbe un incidente critico di livello massimo.